

Table of Contents

Cisco Secure Workload — UK NCSC Cyber Assessment Framework (CAF)

Compliance Report | Operators of Essential Services & GovAssure

Framework: NCSC Cyber Assessment Framework (CAF v3.2, November 2024) **Regulatory context:** NIS Regulations 2018 (UK) for OES and RDSPs; GovAssure for UK central government departments and arm's-length bodies **Audience:** CISO, CAF lead / GRC, Competent Authority-facing assurance teams, GovAssure sponsors

How to read this report

CAF is a **principle-based, outcome-focused** assessment framework. It does not prescribe technology; it asks whether an operator can **demonstrate the outcome** for the systems that support each essential function, at one of three IGP (Indicator of Good Practice) maturity levels:

IGP status	Meaning to the Competent Authority
Achieved	Outcome is fully met with formalised, automated, continuously verified controls.
Partially Achieved	Basic controls exist or are implemented across parts of the estate, but gaps or manual inconsistencies remain.
Not Achieved	Controls are inadequate; unacceptable risk to essential function.

This report describes the CAF principles Cisco Secure Workload (CSW) directly addresses, the principles it partially addresses, and the principles that must be evidenced by other controls. It is not an NCSC certification; it is a mapping to help operators structure their evidence submission and identify credible "**Partially Achieved** → **Achieved**" moves.

1. Executive Summary

Cisco Secure Workload gives UK CNI operators and central-government departments **continuous, machine-generated evidence** for a specific and important subset of the 14 CAF principles — the outcomes where regulators most consistently mark operators as *Partially*

Achieved because the evidence is a static diagram, a quarterly spreadsheet, or an annual firewall sample.

The CAF outcomes where CSW is a **primary** evidence source are:

- **A3 Asset Management** — continuous, real-time inventory of workloads and services supporting each essential function, across on-prem and cloud.
- **B5 Resilient Networks & Systems** — structural segmentation between corporate IT, IT/OT DMZ, and OT/SCADA tiers; microsegmentation within each tier; behaviour-derived allowlists.
- **C1 Security Monitoring** — continuous flow and process telemetry with synchronised time, forwarded to the SIEM/SOAR.
- **C2 Proactive Event Discovery** — behavioural anomaly detection, reachability-weighted vulnerability prioritisation, and threat-intel-fed workspace rules.

The outcomes where CSW is a **partial or supporting** evidence source are: **A1 Governance**, **A2 Risk Management**, **A4 Supply Chain**, **B1 Service Protection Policies & Processes**, **B2 Identity & Access Control**, **B3 Data Security**, **B4 System Security**, **D1 Response & Recovery Planning**, and **D2 Improvements**.

The outcome not addressed by CSW is **B6 Staff Awareness & Training** (organisational / HR).

Deploying CSW as the "continuous-evidence tier" is a defensible way to move A3, B5, C1, C2, and the forensic pillar of D1 from *Partially Achieved* to *Achieved* in the next CAF review or GovAssure engagement.

2. Compliance Posture Summary

Objective	Principle	CSW coverage	Move CSW enables
A — Managing security risk	A1 Governance	Supporting	Feeds board pack with coverage %, denies, unresolved exceptions
	A2 Risk management	Supporting	Provides reachability + attack-surface inputs to dynamic threat modelling
	A3 Asset management	Core	Partially Achieved → Achieved
	A4 Supply chain	Partial	Vendor-egress reconciliation vs.

Objective	Principle	CSW coverage	Move CSW enables
B — Protecting against cyber attack	B1 Service protection policies & processes	Supporting	supplier register Proves policies operate (enforcement + denies telemetry)
	B2 Identity & access control	Partial	Adds workload-to-workload least privilege; does not replace IAM/MFA/PAM
	B3 Data security	Partial	Enforces protected paths and egress denies; does not manage crypto primitives
	B4 System security	Strong	Baseline / drift / VA reachability weighting
	B5 Resilient networks & systems	Core	Partially Achieved → Achieved
	B6 Staff awareness & training	Not addressed	—
C — Detecting cyber security events	C1 Security monitoring	Core	Partially Achieved → Achieved
	C2 Proactive event discovery	Strong	Partially Achieved → Achieved
D — Minimising the impact of incidents	D1 Response & recovery planning	Partial (forensic pillar)	Adds forensic timeline + policy diff to the CIRP evidence pack
	D2 Improvements	Supporting	Policy + inventory diffs feed post-incident RCA

3. Mapping Table — CAF Principle → CSW Capability → Evidence Artefact

Objective A — Managing Security Risk

CAF principle	CSW capability	Evidence artefact for the Competent Authority
A1 Governance	Coverage %, denies count, unresolved exceptions dashboard	Quarterly board-pack extract (PDF); management-review minutes reference the pack
A2 Risk management	Reachability + attack-surface snapshots per essential-function scope	Reachability report; delta between quarterly snapshots showing evolving posture
A3 Asset management	Continuous inventory of workloads / services / cloud resources; CMDB reconciliation; label discipline against essential-function names	Inventory CSV filtered by essential function; agent-status / connector-coverage report; reconciliation report vs. CMDB
A4 Supply chain	Vendor-egress observations; jump-host session evidence; reconciliation against supplier register	Vendor-egress reconciliation report; policy exception register for supplier-specific allowlist entries

Objective B — Protecting Against Cyber Attack

CAF principle	CSW capability	Evidence artefact
B1 Service protection policies & processes	Policy enforcement + Denied-Connections telemetry proves policy is operational, not aspirational	Policy JSON export; denies report per essential function; documented negative-test outcome
B2 Identity & access control	Workload-to-workload allowlist; deny lateral reach; identity-labelled flows when integrated with IAM	Allowlist policy; flow log with user / process context; least-privilege reach report
B3 Data security	Enforce plaintext-protocol deny; egress-to-Internet allowlist; anomaly on data-volume	Policy showing deny for cleartext protocols; egress-anomaly report per essential function

CAF principle	CSW capability	Evidence artefact
B4 System security	egress Process / binary / listening-service inventory; drift alerts; VA connector for reachability-weighted CVE reports	Baseline vs. current diff per host; VA reachability-weighted CVE report
B5 Resilient networks & systems	ADM-derived allowlists; scope hierarchy mirroring essential- function tiers; conduit- level enforcement between IT / IT-OT- DMZ / OT	ADM diagram; policy export; Simulation clean-run report; denies report for the boundary
B6 Staff awareness & training	Not addressed	—

Objective C — Detecting Cyber Security Events

CAF principle	CSW capability	Evidence artefact
C1 Security monitoring	Continuous flow + process telemetry retention; syslog / Kafka / cloud connector to SIEM; NTP-verified timestamps	Retention policy screenshot; SIEM ingest sample proving telemetry flow is live; NTP-drift report
C2 Proactive event discovery	Behavioural anomaly alerts (new listener, new peer, unusual volume); reachability-weighted CVE alerts; threat-intel- fed workspace rules	Anomaly alert catalog; CVE-reachability report; workspace change history tied to threat- intel feeds

Objective D — Minimising the Impact of Incidents

CAF principle	CSW capability	Evidence artefact
D1 Response & recovery planning (forensic pillar)	Historical flow + process telemetry; policy diff timeline; per-workload change history	Forensic timeline export scoped to the incident window; policy-diff report for the same window

CAF principle	CSW capability	Evidence artefact
D2 Improvements	Policy + inventory diff history feeds RCA; workspace change log traces control evolution	Workspace change log; policy-diff summary per incident; RCA appendix citing CSW evidence

4. Out-of-Scope and Complementary Controls

The following CAF outcomes are **not** addressed by CSW and must be evidenced by other controls, processes, or products:

CAF area	Why CSW is not the evidence source	Where to source evidence
A1 Board / SMT governance decisions	Organisational — not a technical control	Board minutes; security-committee terms of reference
A2 Enterprise risk methodology + treatment plans	Process — CSW provides inputs, not the methodology	GRC platform; risk register
A4 Supplier contracts, audits, and assurance clauses	Procurement — CSW helps reconcile egress but does not author contracts	Contract management system; supplier assurance reports
B1 Written policy authoring, exception register, management review	Policy governance — CSW enforces, does not author	ISMS documentation; management review minutes
B2 MFA, PAM, IAM, credential lifecycle	Identity plane — CSW consumes identity context but does not authenticate users	Okta / Entra ID / CyberArk / equivalent
B3 Cryptographic primitives, keys, HSM governance	CSW enforces protected paths; does not manage keys	KMS / HSM inventory; key ceremony evidence
B4 Patching operation itself (deploying the patch)	CSW prioritises; does not deploy	Patch management platform (SCCM, Intune, Landscape, Ansible, Salt)
B5 OT device-layer segmentation (Purdue L0–L2)	CSW is IT-side; does not enforce on PLCs / RTUs / IEDs	Cisco Cyber Vision / Claroty xDome / Nozomi Networks
B6 Training programme, phishing simulations	Organisational — HR / learning	LMS; phishing-simulation platform

CAF area	Why CSW is not the evidence source	Where to source evidence
D1 Backups, immutability, RTO/RPO testing	CSW does not perform backup or restore	Backup platform; DR exercise reports
D2 Formal lessons-learned documentation	Process — CSW supplies inputs, not the process artefact	Incident management platform; management review

5. Suggested Next Steps

1. **Scope confirmation.** Align on the list of essential functions in scope and confirm the sector profile the Competent Authority applies.
2. **Deploy CSW to the highest-value tier first** — IT/OT DMZ workloads, jump hosts, and any workload with reach into an essential-function OT zone.
3. **Baseline for two weeks** using ADM; walk the resulting flow map through with each essential-function owner.
4. **Design and simulate policy** per essential function; do not enforce until a clean Simulation window and change-board sign-off.
5. **Wire telemetry to the SIEM/SOAR** with NTP-verified timestamps — this is the C1 evidence baseline.
6. **Produce the first quarterly CAF pack** per essential function (see the runbook's *Audit preparation & evidence export* section) and use it to identify credible *Partially Achieved* → *Achieved* moves with your Competent Authority.
7. **Repeat quarterly**, capturing policy diffs and ADM refreshes; these are the D2 improvement inputs.

6. Disclaimer

This report maps Cisco Secure Workload capabilities to the outcomes described in the UK NCSC Cyber Assessment Framework (CAF v3.2, November 2024) for the purpose of aiding operator evidence collection. It is **not** an NCSC-endorsed certification, is **not** a substitute for an independent CAF assessment or GovAssure engagement, and does **not** confer any IGP maturity status. Awarding of IGP status is the responsibility of the operator's Competent Authority (Ofgem, DWI, CAA, ORR, MCA, DfT, DHSC/NHS England, Ofcom, ICO) or GovAssure assessor. Cisco Secure Workload is one component of an evidence programme that also depends on organisational governance, procurement, HR, business continuity, and training controls outside CSW's technical scope. Confirm your sector profile and any Competent Authority-specific guidance before finalising evidence.